



.COM

Web Application Penetration Testing Report

DECEMBER 2025

PREPARED BY
MIR MUHAMMED AHSAN ALI

CONTACT
@M999ALI
ali.codes1279@gmail.com



Limitations on Disclosure and Use of this Document

This report is prepared for the first Web Application Pentesting Practical Exam of the Second Batch of the Advance Web Application Security Testing & Professional Bug Bounty course. Unauthorized use or reproduction of this document is prohibited. The confidentiality and the disclosure of this report is being governed by the standards Non-Disclosure Agreement (NDA).

This report contains information about potential vulnerabilities of an asset of [REDACTED] and methods for exploiting them. Special precautions must be taken to protect the confidentiality of both this document and the information contained herein. A copy of this report is submitted to the examiner via the submission link provided by the Byte Capsule authority.

By providing this report, the inviolable security of the asset is not being constituted by any form of presentation, warranty, or guarantee. While the applied methodology includes both automated and manual testing to identify and attempt exploitation of the most common security issues.

Document Details

Title	Web Application (Black Box) Penetration Testing Report
Project Resource	Mir Muhammed Ahsan Ali
Project Duration	04/12/2025 – 14/12/2025

Contents

Exclusive Summary	3
Scope of the assessment:	3
Issues by risk factor:	3
Assessment Methodology	4
Checklist with the video POC links	4
Assessment Findings	6
■ High Risk Findings	6
H1: Missing HTTP Headers Expose Site to Client-Side Attacks	6
H2: Directory Listing Enabled and Sensitive Paths Exposed	8
H3: Missing Rate Limiting Allows Unlimited Brute-Force Attempts	10
H4: Multiple End-of-Life (EOL) and Outdated Software Components	11
■ Medium Risk Findings	12
M1: Open FTP Service Exposed on Port 21	13
M2: Sensitive Cookies Lack the HttpOnly Flag	13
M3: Paging Logic Flaw (Input Manipulation)	14
M4: Password Policy Fails to Enforce Complexity Requirements	16
M5: Critical Forms Lack CAPTCHA for Bot Prevention	17
M6: Application Vulnerable to Clickjacking Attack (Missing Frame Defenses)	18
M7: Administrative Template File Exposed via Directory Listing	19
M8: Continued Support for Obsolete CBC-Mode Ciphers	20
■ Low Risk Findings	21
L1: Excessive Services Exposed with Version Disclosure	21
L2: Application Accepts Disposable Email Addresses (DEA)	22
Conclusion	24



Exclusive Summary

Vulnerability assessment is performed on [REDACTED].com by maintaining the rules of the exam and following the provided checklist. Candidates were told to provide several POCs to prove the report is unique and doesn't contain other candidate's material. The links of the POCs are provided in the checklist.

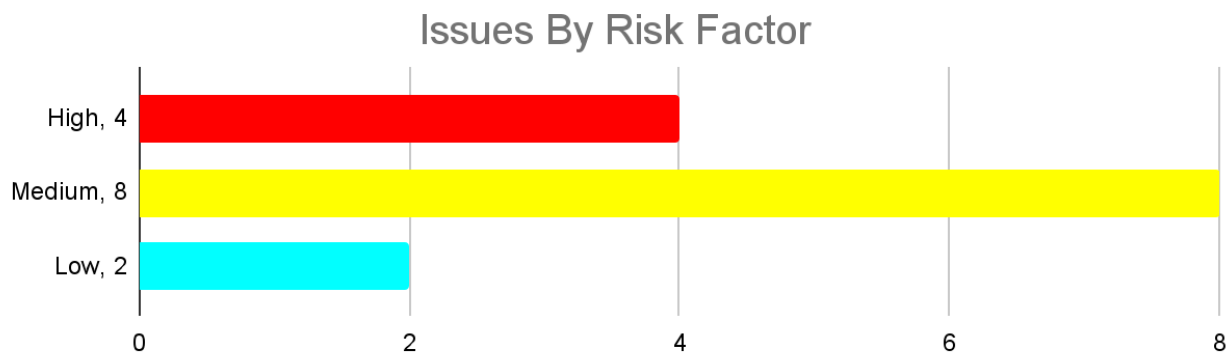
Scope of the assessment:

[https://\[REDACTED\].com/](https://[REDACTED].com/)

Including all the subdomains.

Issues by risk factor:

The issues that are found are ranked by risk factors.



Assessment Methodology

The findings are based on the methodology which is provided by the ByteCapsule authority through a checklist. Both automated scan and manual testing is done for assessing the application following the checklist. The report is mostly focused on vulnerability assessment rather than solely on penetration testing due to the short duration of the project. The Folder containing the POCs can be found in the link below:
[https://drive.google.com/drive/folders/\[REDACTED\]?usp=sharing](https://drive.google.com/drive/folders/[REDACTED]?usp=sharing)

Checklist with the video POC links

Here is the checklist with the findings and POC links:

Checklist	Findings
INFORMATION GATHERING	
1. Open Source Reconnaissance	
2. Fingerprinting Web Server	H4 L1
3. Looking For Metafiles	
4. Enumerating Web Server's Applications	Video POC 1
5. Review The Web Contents	
6. Identifying Application's Entry Points	
7. Mapping Execution Paths	
8. Fingerprint Web Application Framework	H1
9. Configuration & Deployment Management Testing	M1
10. Review Backup & Unreferenced Files	
11. Enumerate Infrastructure & Admin Interfaces	M7
12. Testing HTTP Methods	
13. Test File Permission	H2
14. Test For Subdomain Takeover/DNS Takeover	
IDENTITY MANAGEMENT TESTING	

15. Test Role Definitions	
16. Test User Registration Process	L2
17. Testing For Account Enumeration	
18. Test For Weak Username Policy	
AUTHENTICATION TESTING	
19. Test For Un-Encrypted Channel	
20. Test For Default Credentials	
21. Test For Weak Lockout Mechanism	M5
22. Test For Bypassing Authentication Schema	
23. Test For Weak Password Policy	M4
24. Testing For Weak Security	H3
25. Test For Weak Password Reset Function	
26. Test For Weak Password Change Function	Video POC 2
27. Test For Weak 2FA	
28. Test For Weak OTP Implementation	
AUTHORIZATION TESTING	
29. Test for IDOR	
30. Test Authorization Schema Bypass	
31. Test For Privilege Escalation	Video POC 4
SESSION MANAGEMENT TESTING	Video POC 5
33. Test For Session Management Schema	M2
34. Test For Session Fixation	
35. Test For Exposed Session Variables	
36. Test For Back Refresh Attack	
37. Test For SQL Injection	Video POC 9
38. Test For Reflected Cross Site Scripting	Video POC 6
39. Test For Stored Cross Site Scripting	Video POC 7

40. DOM-based XSS Testing	Video POC 8
ERROR HANDLING TESTING	Video POC 10
41. Test For Improper Error Handling	
WEAK CRYPTOGRAPHY TESTING	
42. Test For Weak Transport Layer Security	M8
43. Test For Command Injection	
BUSINESS LOGIC TESTING	
44. Test For Business Logic	M3
45. Test For Malicious File Upload	
46. Test For Cross Origin Resource Sharing	
47. Test For Clickjacking	M6 with Video POC 11
48. Host Header Injection Testing	
49. Testing for Reverse Tabnabbing/Tabnabbing	
50. CRLF (Carriage Return Line Feed) Injection Testing	

Assessment Findings

High Risk Findings

H1: Missing HTTP Headers Expose Site to Client-Side Attacks

Severity: High

Description

The server is missing several key HTTP security headers, leaving the web application vulnerable to common client-side attacks that browsers are designed to mitigate. Specifically, the lack of:

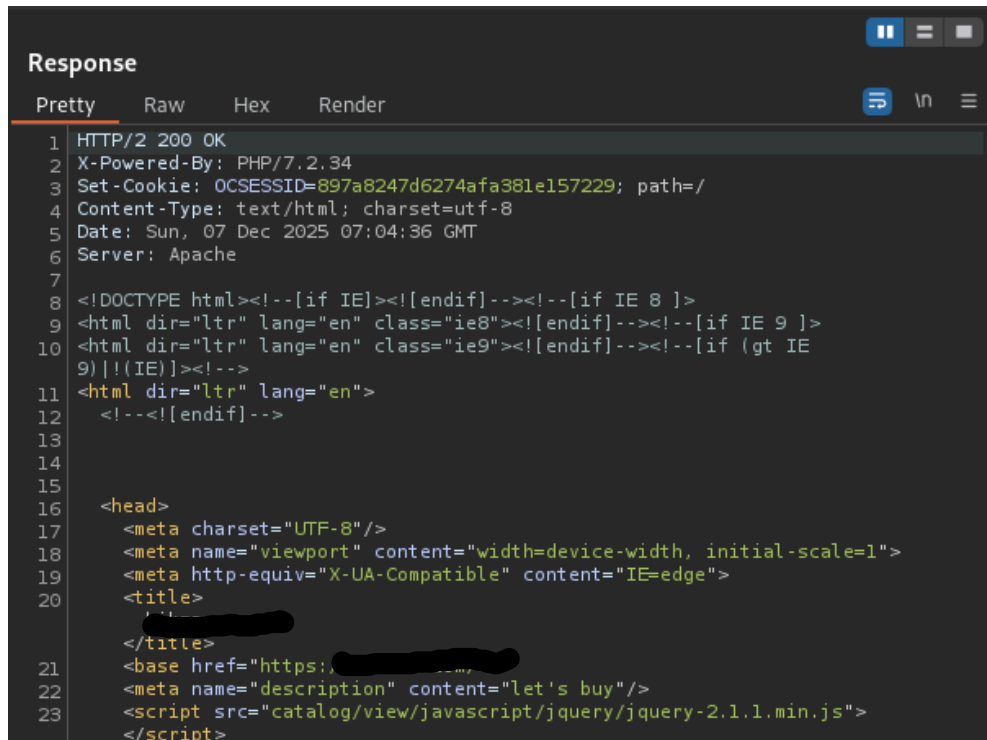
1. **X-Frame-Options** (or CSP's **frame-ancestors** directive) exposes the site to Clickjacking.
2. **X-Content-Type-Options** exposes the site to MIME-sniffing attacks.
3. **Content-Security-Policy (CSP)** exposes the site to a much wider range of Cross-Site Scripting (XSS) and data injection attacks.
4. **Strict-Transport-Security (HSTS)** does not enforce HTTPS, risking protocol downgrade attacks (Man-in-the-Middle).

CWE-1021: Improper Restriction of Rendered UI Layers (Clickjacking)

Affected Functionality

Clickjacking, Cross-Site Scripting (XSS), Data Integrity/Confidentiality.

Proof of Concept



```
Response
Pretty Raw Hex Render
1 HTTP/2 200 OK
2 X-Powered-By: PHP/7.2.34
3 Set-Cookie: OCSESSID=897a8247d6274afa381e157229; path=/
4 Content-Type: text/html; charset=utf-8
5 Date: Sun, 07 Dec 2025 07:04:36 GMT
6 Server: Apache
7
8 <!DOCTYPE html><!--[if IE]><![endif]--><!--[if IE 8 ]>
9 <html dir="ltr" lang="en" class="ie8"><![endif]--><!--[if IE 9 ]>
10 <html dir="ltr" lang="en" class="ie9"><![endif]--><!--[if (gt IE
11 9)|(IE)]><!-->
12 <html dir="ltr" lang="en">
13 <!--<![endif]-->
14
15
16 <head>
17 <meta charset="UTF-8"/>
18 <meta name="viewport" content="width=device-width, initial-scale=1">
19 <meta http-equiv="X-UA-Compatible" content="IE=edge">
20 <title>
21 </title>
22 <base href="https://[redacted]/">
23 <meta name="description" content="let's buy"/>
24 <script src="catalog/view/javascript/jquery/jquery-2.1.1.min.js">
25 </script>
```

Recommendation

Implement all missing headers, especially **X-Frame-Options: DENY** or **SAMEORIGIN** and a comprehensive **Content-Security-Policy**, to instruct browsers on security enforcement.

H2: Directory Listing Enabled and Sensitive Paths Exposed

Severity: High

Description

The web server is misconfigured, allowing directory listing (Index of /) for multiple sensitive directories, including:

- /image/
- /catalog/ (and subdirectories like /catalog/language/en-gb/)
- /website/
- /simple/
- /admin/view/

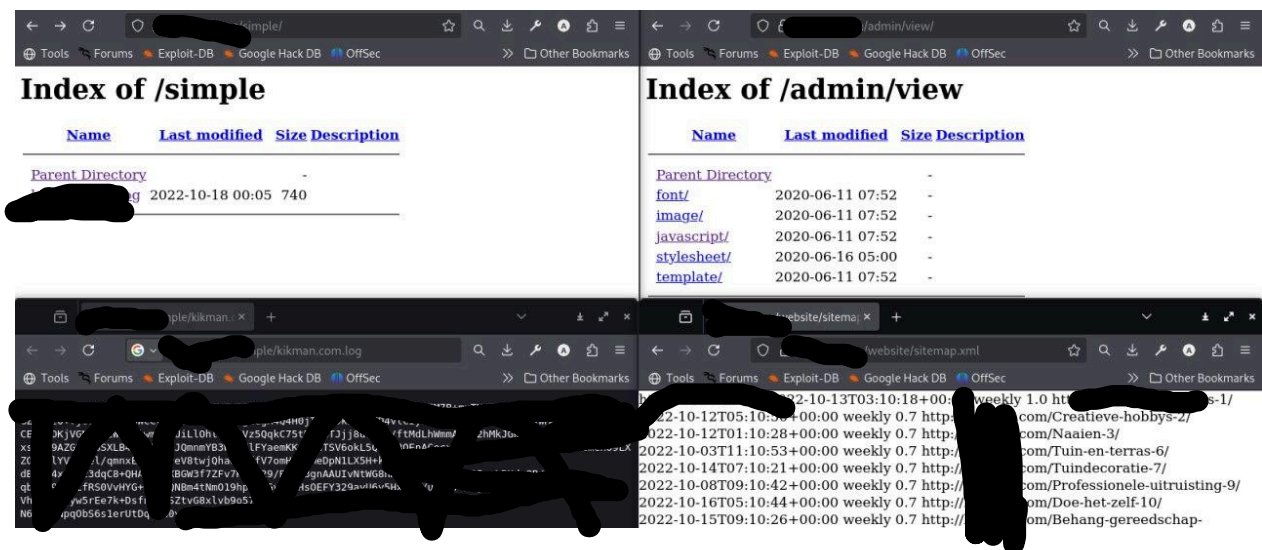
This flaw allows attackers to see the exact structure, file names, and timestamps of the application's source code, logs (e.g., /simple/[REDACTED].com.log), and administrative files (/admin/view/). The exposure of file paths and logs significantly aids in reconnaissance for targeted attacks, such as identifying vulnerable components or extracting session data from the log file content.

CWE-548: Information Exposure Through Directory Listing

Affected Functionality

Information Disclosure, Attack Surface Area, System Reconnaissance.

Proof of Concept



Recommendation

Disable the directory listing feature globally in the web server configuration (e.g., using `Options -Indexes` in Apache or equivalent directives). For directories that require public access, use an index file (e.g., `index.html`).

H3: Missing Rate Limiting Allows Unlimited Brute-Force Attempts

Severity: High

Description

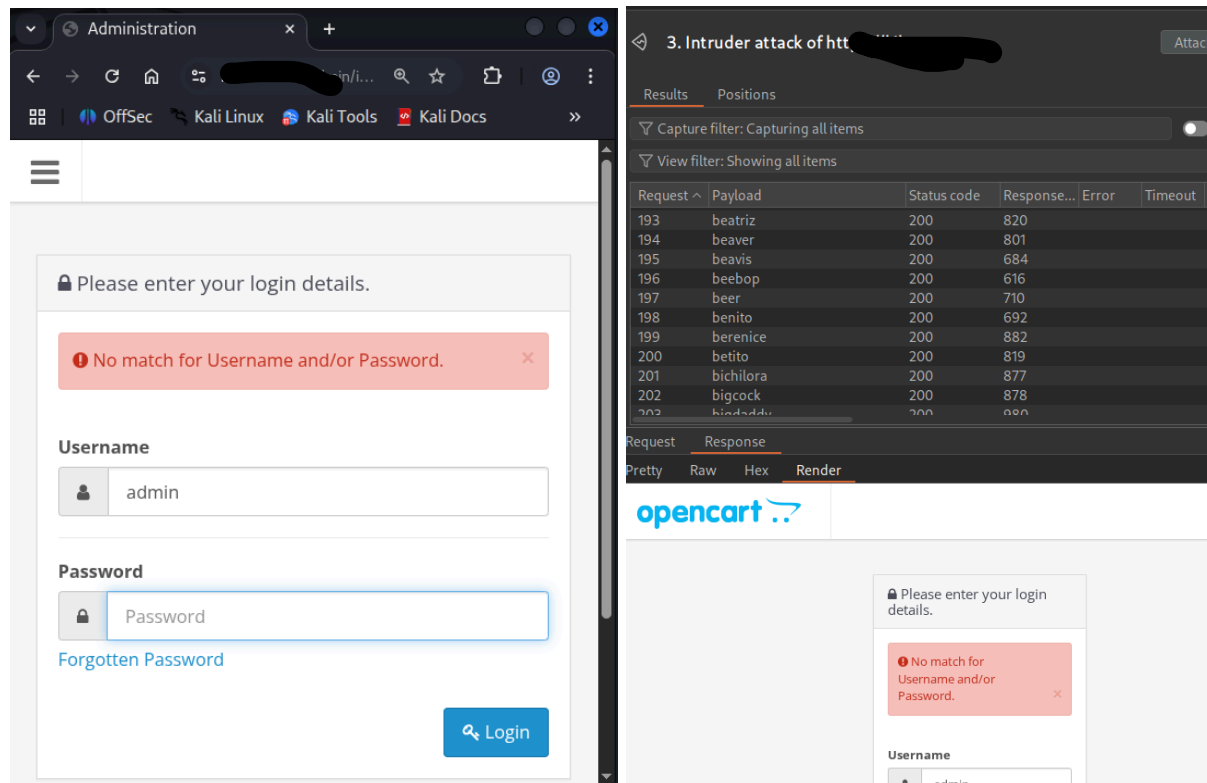
The authentication mechanism for the login page [https://\[REDACTED\].com/admin/](https://[REDACTED].com/admin/) lacks **adequate rate limiting** (a limitation on the number of attempts allowed within a given time period). The tester was able to submit numerous login attempts in rapid succession without encountering any captchas, or delays. This fundamental security weakness allows an attacker to perform an **online brute-force or dictionary attack** against user accounts to guess valid passwords. This could lead to account compromise, especially for users with weak passwords.

CWE-307: Improper Restriction of Excessive Authentication Attempts

Affected Functionality

User Authentication, Confidentiality (Account Compromise).

Proof of Concept



Recommendation

Implement a robust **rate limiting** policy. For example, impose an increasing delay after 5 failed attempts per IP address/user/session within a 5-minute window. Also, use **CAPTCHAs** after a few failed attempts.

H4: Multiple End-of-Life (EOL) and Outdated Software Components

Severity: Critical

Description

The server exposes multiple critical services running on **End-of-Life (EOL)** or severely **outdated** versions, which no longer receive security patches. Key components include

MariaDB 5.5 (EOL since April 2020) and PHP 7.2.34 (EOL since November 2020). These versions are vulnerable to numerous publicly known critical exploits.

CVE-2021-36749 (MariaDB)

CVE-2023-45607 (OpenCart)

CVE-2019-11040 (PHP)

Affected Functionality

System Integrity, Confidentiality, E-commerce Data.

Proof of Concept

```
(kali@kali)-[~]
$ nmap -sV [redacted]
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-08 01:25 +06
Nmap scan report for [redacted] (199.250.1.100)
Host is up (0.32s latency).
Other addresses for [redacted] (not scanned): [redacted]
rDNS record for 199.250.1.100: [redacted].hosting.com
Not shown: 958 filtered tcp ports (no-response), 30 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      Pure-FTPd
25/tcp    open  smtp     Exim smtpd 4.98.2
80/tcp    open  http     Apache httpd
110/tcp   open  pop3     Dovecot pop3d
143/tcp   open  imap     Dovecot imapd
443/tcp   open  ssl/http Apache httpd
465/tcp   open  ssl/smtp Exim smtpd 4.98.2
587/tcp   open  smtp     Exim smtpd 4.98.2
993/tcp   open  ssl/imap Dovecot imapd
995/tcp   open  ssl/pop3 Dovecot pop3d
2222/tcp  open  ssh      OpenSSH 8.0 (protocol 2.0)
3306/tcp  open  mysql    MySQL 5.5.5-10.6.24-MariaDB-log

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 34.29 seconds
```

Recommendation

Immediately upgrade MariaDB and PHP to currently supported, stable versions (e.g., MariaDB 10.11+ LTS, PHP 8.2+). Implement a patch management policy.

Medium Risk Findings:

M1: Open FTP Service Exposed on Port 21

Severity: Medium

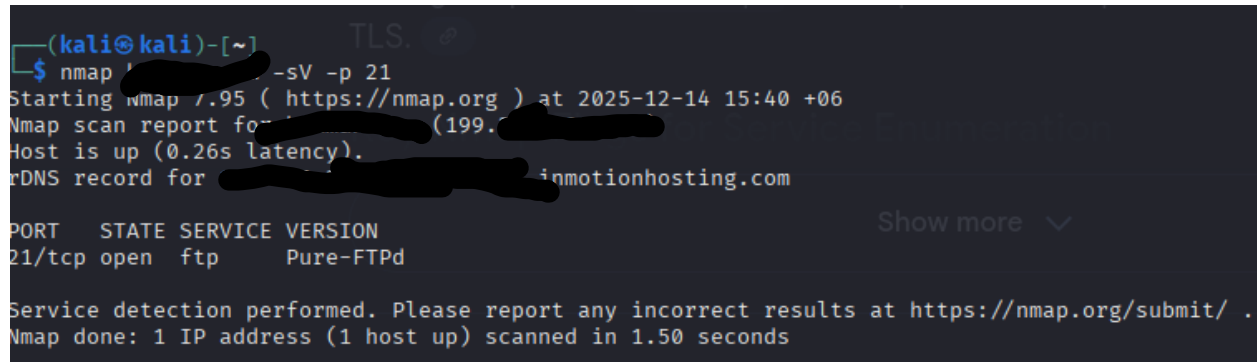
Description

The **Pure-FTPd** service is running on the default port **21/TCP**. The FTP protocol transmits **credentials (usernames and passwords) in cleartext**, allowing an attacker monitoring the network path to easily capture sensitive login details using a network sniffer.

Affected Functionality

File Transfer Security, User Authentication, System Access.

Proof of Concept



```
(kali@kali)-[~] $ nmap -sV -p 21 199.199.199.199
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-14 15:40 +06
Nmap scan report for 199.199.199.199
Host is up (0.26s latency).
DNS record for 199.199.199.199: 199.199.199.199.inmotionhosting.com

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      Pure-FTPd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 1.50 seconds
```

Recommendation

Disable the FTP service (Port 21). Migrate all file transfer operations to the secure and encrypted **SFTP** protocol, which runs over SSH (already available on port 2222).

M2: Sensitive Cookies Lack the HttpOnly Flag

Severity: Medium

Description

The cookies **OCSESSID**, **language**, and **currency** were set without the **HttpOnly** flag. The **HttpOnly** flag prevents client-side script (e.g., JavaScript) from accessing the cookie's value. Without this flag, an attacker who successfully executes a **Cross-Site Scripting (XSS)** attack can easily steal these cookies, which may lead to **session hijacking** if the **OCSESSID** is a session identifier.

CWE-1004: Sensitive Cookie Without 'HttpOnly' Flag

Affected Functionality

User Session Integrity, Confidentiality (Cookie Theft).

Proof of Concept

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly ▼	Secure	SameSite
currency	BDT	[REDACTED].com	/	2026-01-12T16:50:33.92...	11			
language	en-gb	[REDACTED].com	/	2026-01-12T16:50:33.92...	13			
OCSESSID	8cd91babf8c63c16eec7785ae6	[REDACTED].com	/	Session	34			

Showing from the DevTool.

Recommendation

Disable the FTP service (Port 21). Migrate all file transfer operations to the secure and encrypted **SFTP** protocol, which runs over SSH (already available on port 2222).

M3: Paging Logic Flaw (Input Manipulation)

Severity: Medium

Description

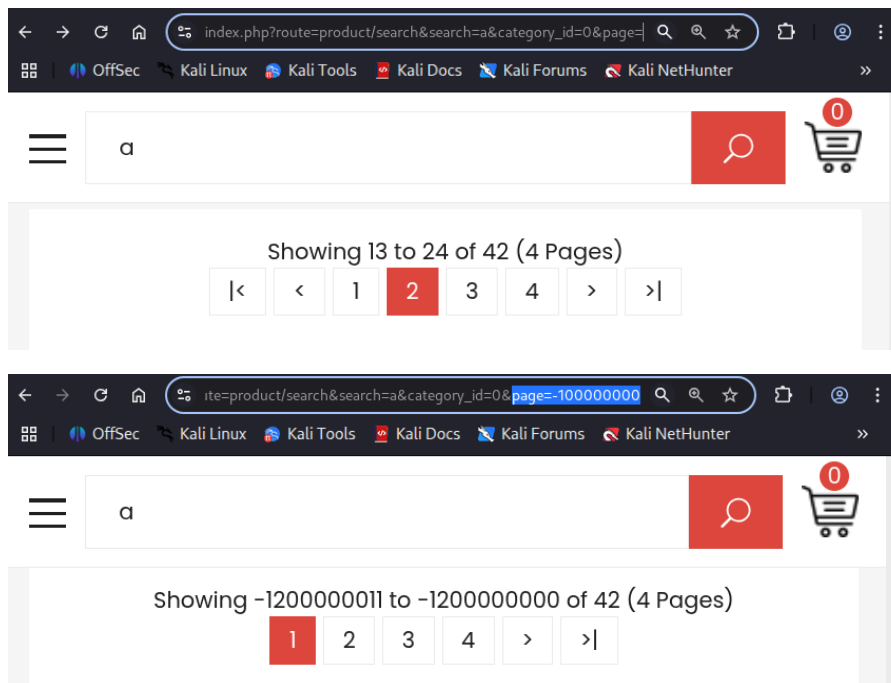
The application's pagination parameter, `page`, allows negative integer input (`page=-10`), which is logically invalid. Instead of rejecting the input or defaulting to the first page, the application attempts to process it, resulting in unexpected output on the webpage: **-65 to -60 of 7**. This behavior indicates a **logic flaw** in the server-side code that calculates the result offset. Such flaws can often be leveraged to cause **errors, excessive resource consumption (DoS), or unexpected information disclosure** by manipulating offsets to view unauthorized or unusual data ranges.

CWE-703: Improper Check or Handling of Exceptional Conditions

Affected Functionality

Application Logic, Data integrity (Offset Calculation), Stability (DoS risk).

Proof of Concept



Recommendation

Implement strict **server-side validation** for the **page** parameter to ensure it is a positive integer greater than zero. If an invalid or negative value is received, the application should default to **page=1**.

M4: Password Policy Fails to Enforce Complexity Requirements

Severity: Medium

Description

The password policy enforced during user registration is too weak, requiring only a minimum length of **4 characters**. This lack of complexity enforcement (uppercase, lowercase, numbers, special characters) allows users to set highly predictable and easily guessable passwords. Weak passwords significantly increase the risk of successful **credential stuffing** attacks, where stolen passwords from other breaches are used against this application.

CWE-521: Weak Password Requirements

Affected Functionality

User Account Security, Confidentiality (Account Compromise).

Proof of Concept

The screenshot shows a web browser window with the URL `index.php?route=account/register`. The page has a navigation bar with links: CATEGORIES, HOME, PRODUCTS, BLOG, and CONTACT. Below the navigation bar, there is a registration form. The form includes a 'telephone' field with the value 'gvhgchkckg'. Below that is a 'Your Password' section with two input fields: '* Password' and '* Password Confirm'. Both fields contain four dots, indicating a password of length 4. A red error message is displayed below the '* Password' field: 'Password must be between 4 and 20 characters!'. At the bottom of the form is a 'Newsletter' field.

Recommendation

Enforce a strong password policy requiring a minimum length (e.g., **12 characters**) and complexity, including a mix of **uppercase, lowercase, numbers, and special characters**.

M5: Critical Forms Lack CAPTCHA for Bot Prevention

Severity: Medium

Description

The **account creation (registration)** and **login** forms are missing a CAPTCHA (Completely Automated Public Turing test to tell Computers and Humans Apart) mechanism. The absence of CAPTCHA means there is no effective defense against automated attacks. This deficiency directly facilitates **automated bot attacks**, including:

1. **Mass Account Creation:** Bots can rapidly create thousands of spam or fraudulent accounts, consuming resources and degrading data quality (related to Finding 10).
2. **Credential Stuffing/Brute-Force:** Bots can systematically attempt to log in using massive lists of stolen or guessed credentials (related to Finding 8).

CWE-307: Improper Restriction of Excessive Authentication Attempts

Affected Functionality

Bot Detection, Fraud Prevention, Authentication, Resource Consumption.

Recommendation

Implement a modern, user-friendly **CAPTCHA** or **reCAPTCHA** (or equivalent human verification service) on both the **login** and **account registration** pages to significantly restrict automated activity.

M6: Application Vulnerable to Clickjacking Attack (Missing Frame Defenses)

Severity: Medium

Description

The web application is vulnerable to **Clickjacking** (UI Redressing) attacks because it is missing crucial anti-framing security headers, specifically the **X-Frame-Options** header and the **frame-ancestors** directive within the Content-Security-Policy (CSP). An attacker can embed the vulnerable application page within an invisible **<iframe>** on a malicious website. The attacker can trick a user into clicking elements on the hidden, legitimate page leading to unauthorized actions being performed on the user's behalf.

CWE-1021: Improper Restriction of Rendered UI Layers

Affected Functionality

User Interface Integrity, Authorization, User Actions.

Proof of Concept (click below)

Video POC 11

Recommendation

Implement the **X-Frame-Options** header with a value of **DENY** or **SAMEORIGIN**. Alternatively, implement a robust **Content-Security-Policy** that includes the **frame-ancestors 'self'** directive.

M7: Administrative Template File Exposed via Directory Listing

Severity: Medium

Description

Due to the enabled directory listing, the highly sensitive administrative template file, `/admin/view/template/user/api_form.twig`, is directly accessible without any authentication. This file contains front-end logic and, crucially, **exposes a core administrative API endpoint: `index.php?route=user/api/deletesession`**.

The disclosure of this specific endpoint and its parameters (`user_token`, `api_session_id`) gives an attacker precise knowledge of a function designed to terminate API sessions. This reconnaissance effort significantly reduces the time and complexity required for an attacker to:

1. Craft a targeted attack against this specific API call.
2. Understand the backend structure (OpenCart uses Twig templates for the admin panel).

CWE-540: Inclusion of Sensitive Information in Source Code

Affected Functionality

Information Disclosure, Administrative Reconnaissance, API Security.

Proof of Concept

The left screenshot shows a directory listing for `/admin/view/template/user`. The table below summarizes the files listed:

Name	Last modified	Size	Description
Parent Directory	-	-	-
api_form.twig	2020-04-30 18:24	9.0K	
api_list.twig	2020-04-30 18:24	4.6K	
user_form.twig	2020-04-30 18:24	6.0K	
user_group_form.twig	2020-04-30 18:24	4.1K	
user_group_list.twig	2020-04-30 18:24	3.5K	
user_list.twig	2020-04-30 18:24	4.2K	

The right screenshot shows the source code of the `api_form.twig` file. It contains a JavaScript AJAX call to `index.php?route=user/api/deletesession&user_token={{ user_token }}&api_session_id={{ api_session_id }}`.

Recommendation

High Priority: Immediately **disable directory listing** on the server.

Access Control: Ensure that the `/admin` directory and its contents are protected by robust **file-level access controls** that enforce authentication before serving any files, including templates.

Refactor: Do not embed sensitive endpoint paths directly in client-exposed template files.

M8: Continued Support for Obsolete CBC-Mode Ciphers

Severity: Medium

Description

The server supports Obsolete Cipher Block Chaining (CBC) ciphers (e.g., `ECDHE-RSA-AES256-SHA`, `AES256-SHA`). These CBC-mode ciphers in TLS are potentially vulnerable to timing-based padding oracle attacks, such as **LUCKY13** (CVE-2013-0169). Furthermore, the scan explicitly noted the server is **VULNERABLE to SWEET32** (CVE-2016-2183) due to the use of 64-bit block ciphers like Triple DES (`DES-CBC3-SHA`). While most modern browsers prioritize stronger ciphers, the availability of these weak ciphers exposes older clients and allows attackers to downgrade the connection if successful.

CVE-2013-0169 (LUCKY13)

CVE-2016-2183 (SWEET32)

Affected Functionality

Confidentiality (Data Encryption), TLS Integrity.

Proof of Concept

Running client simulations (HTTP) via sockets			
Browser	Protocol	Cipher Suite Name (OpenSSL)	Forward Secrecy
Android 7.0 (native)	TLSv1.2	ECDHE-RSA-AES128-GCM-SHA256	256 bit ECDH (P-256)
Android 8.1 (native)	TLSv1.2	ECDHE-RSA-AES128-GCM-SHA256	253 bit ECDH (X25519)
Android 9.0 (native)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Android 10.0 (native)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Android 11/12 (native)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Android 13/14 (native)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Android 15 (native)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Chrome 101 (Win 10)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Chromium 137 (Win 11)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Firefox 100 (Win 10)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
Firefox 137 (Win 11)	TLSv1.3	TLS_AES_128_GCM_SHA256	253 bit ECDH (X25519)
IE 8 Win 7	No connection		
IE 11 Win 7	TLSv1.2	ECDHE-RSA-AES256-SHA384	256 bit ECDH (P-256)
IE 11 Win 8.1	TLSv1.2	ECDHE-RSA-AES256-SHA384	256 bit ECDH (P-256)
IE 11 Win Phone 8.1	TLSv1.2	AES128-SHA256	No FS

Recommendation

Disable all obsolete CBC-mode ciphers (ending in **-SHA**, **-SHA256**, or similar) and 64-bit block ciphers (Triple DES, Camellia, SEED) in the server configuration, favoring modern AEAD ciphers (GCM or ChaCha20-Poly1305).

Low Risk Findings:

L1: Excessive Services Exposed with Version Disclosure

Severity: Low

Description

The server exposes an unnecessary number of services publicly (e.g., FTP, multiple Mail protocols, Database port 3306). Additionally, key services like **Apache**, **Exim**, and **MariaDB** openly disclose their **full version numbers** in service banners, simplifying the process for an attacker to identify known exploits.

Affected Functionality

Information Disclosure, Attack Surface Area.

Proof of Concept

```
(kali@kali)-[~]
$ nmap -sV [REDACTED]
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-08 01:25 +06
Nmap scan report for [REDACTED] (199.192.148.1)
Host is up (0.32s latency).
Other addresses for [REDACTED] (not scanned): 64:ff9c:1::1
rDNS record for 199.192.148.1: [REDACTED].inmotionhosting.com
Not shown: 958 filtered tcp ports (no-response), 30 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      Pure-FTPd
25/tcp    open  smtp     Exim smtpd 4.98.2
80/tcp    open  http     Apache httpd
110/tcp   open  pop3     Dovecot pop3d
143/tcp   open  imap     Dovecot imapd
443/tcp   open  ssl/http Apache httpd
465/tcp   open  ssl/smtp Exim smtpd 4.98.2
587/tcp   open  smtp     Exim smtpd 4.98.2
993/tcp   open  ssl/imap Dovecot imapd
995/tcp   open  ssl/pop3 Dovecot pop3d
2222/tcp  open  ssh      OpenSSH 8.0 (protocol 2.0)
3306/tcp  open  mysql    MySQL 5.5.5-10.6.24-MariaDB-log

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 34.29 seconds
```

Recommendation

Filter non-essential ports (e.g., 3306, administrative ports) at the firewall. Configure services (Apache, Exim) to **suppress or mask** their version and build information in response headers/banners.

L2: Application Accepts Disposable Email Addresses (DEA)

Severity: Low

Description

The application permits users to register accounts using **Disposable Email Addresses (DEA)**, also known as burner emails (e.g., mailinator.com, temp-mail.org). These addresses are intended for temporary use and lack a long-term mailbox. While this is not a direct technical vulnerability like SQL injection, it poses a risk to **data integrity** and the effectiveness of certain security controls. It prevents the organization from effectively communicating with users (e.g., password reset, service notifications) and makes it easier

for bad actors to create **multiple fraudulent accounts** or evade temporary bans and restrictions.

CWE-732: Incorrect Permission Assignment for Critical Resource

Affected Functionality

Data Quality, Fraud Prevention, Account Verification.

Proof of Concept

The image displays two side-by-side screenshots of a web application interface. The left screenshot shows a 'REGISTER ACCOUNT' form. At the top, there is a search bar and a shopping cart icon. The form includes a message: 'If you already have an account with us, please login at the login page.' Below this, the section 'Your Personal Details' contains five required fields: 'First Name' (with 'Wo' entered), 'Last Name' (with 'Ye' entered), 'E-Mail' (with 'h...@ocsfy.com' entered), 'Telephone' (with '15771...' entered), and 'Your Password'. The right screenshot shows a 'Save password?' dialog box with a 'Save' button. Below the dialog, a success message reads: 'YOUR ACCOUNT HAS BEEN CREATED! Congratulations! Your new account has been successfully created! You can now take advantage of member privileges to enhance your online shopping experience with us. If you have ANY questions about the operation of this online shop, please e-mail the store owner. A confirmation has been sent to the provided e-mail address. If you have not received it within the hour, please contact us.' A red 'CONTINUE' button is at the bottom right.

Recommendation

Implement an email validation service or maintain a **blocklist of known disposable email domains** at the point of registration. Flag or deny registration attempts using domains associated with disposable email providers.



Conclusion

This testing was based on the technologies and known threats as of the date of this document. All the security issues discovered during that exercise were analyzed and described in this report. Please note that as technologies and risks change over time, the vulnerabilities associated with the operation of systems described in this report, as well as the actions necessary to reduce the exposure to such vulnerabilities, will also change.